cloudsync-soa-toolkit

Passwordless and always able to sign in: cloud users in Active Directory, provisioned by Microsoft Entra Cloud Sync and protected by AD object enforcement

Status 2.1.1 (2026-10-23). Entra ID → AD provisioning and AD object enforcement are **preview** features. Independent community project, not affiliated with Microsoft; validate in a lab.

Evidence levels. Documented = Microsoft documentation, protocol specification or source code. **Observed** = measured in a domain with the previews (WS2025 DCs, DFL 2025, two writable DCs that are also agent hosts). **Inferred** = derived.

Verification status. The findings marked Observed were measured manually by the maintainer. The end-to-end lab validation of the 2.x scripts (checklist L1-L20) is in progress - see docs/VALIDATION.md. The project was built with extensive AI assistance and is reviewed by the maintainer (README, "How this project was built").

1. Executive summary

- **Problem.** Users provisioned by Cloud Sync never know an AD password and sign in passwordless (WHfB / FIDO2 via Cloud Kerberos Trust, AVD SSO). Their AD password still ages, and an **expired AD password blocks the passwordless Kerberos sign-in** (Documented).
- **Solution.** Make the accounts smart-card-only (SCRIL). Let the DCs roll the hidden secret at the first passwordless sign-in after expiry (automatic rolling). Control the interval with one fine-grained password policy, and freeze the result with AD object enforcement.
- **Evidence.** Setting SCRIL re-randomizes the secret. With rolling enabled, SCRIL secrets expire on schedule. A WHfB / FIDO2 sign-in via Cloud Kerberos Trust, with AVD SSO and access to a file share, **succeeded after expiry, and the DC rolled the secret during that sign-in** (Observed). "Password never expires" disables the rolling (Observed).
- **Toolkit.** Idempotent, reversible setup. Event-triggered onboarding on every writable DC and a reconcile on every agent host (no management server, no single point of failure). Read-only monitoring, acceptance tests and a step-by-step rollback. The toolkit never rotates, knows or stores a password.

2. Target state

Object	Setting	Reason
Domain	DFL ≥ 2016, msDS-ExpirePasswordsOnSmartCardOnlyAccounts = TRUE	Prerequisites for automatic rolling (K9, K13)
Cloud user (User_*, msDS-ObjectSoa = Cloud)	**SCRIL set**; **password never expires cleared**; no deny-change ACEs; member of SOA-CloudUsers-PSO	Random secret rolled by the DC (K10, K11, K16); PNE disables rolling (K17); ACEs have no effect (K18); synced groups are universal (K19)
PSO-SOA-CloudUsers (precedence 10)	Max age 30 days, min age 1 day, min length 64, complexity on, history 24, reversible off, lockout threshold 0	Rolling interval within DISA STIG ≤ 60 days; lockout would only allow DoS against unguessable secrets
AD object enforcement	Allow-list = all agent gMSAs + toolkit gMSA; Audit phase, then Enforced	Only the source of authority changes marked objects

3. What the toolkit does

Capability	Script	Writes
Prerequisites per DC (engine, KIR, RSoP, container origin) + toolkit prerequisites	Test-SoaPrerequisites.ps1	–

Capability	Script	Writes
Setup: gMSA, batch logon GPO, KIR GPO from Microsoft's MSI (one per OS, WMI filter), diagnostics GPO, audit GPO + own narrow msDS-ObjectSoa SACL (monitored), rolling, policy, groups, PSO, delegation, allow-list, tasks	Install-SoaToolkit.ps1	AD, GPOs, hosts
Initial analysis + target state for existing cloud-only / SOA-converted users	Install-SoaToolkit.ps1 -Step Conform	users, PSO group
Onboarding on events 4720 / 5136 by the agent, on every writable DC; reconcile on every agent host	Invoke-CloudUserConformance.ps1	users, PSO group
Monitoring: event log SoaToolkit (2000 / 2001 / 2002), exit code 0/1/2, HTML	Watch-CloudUserConformance.ps1	event log
Impact of Enforced mode	Get-SoaEnforcementImpact.ps1	–
Acceptance tests (SCRIL matrix, rolling with a real sign-in, onboarding, enforcement, logon)	Test-SoaBehavior.ps1	TestUser only
Step-by-step rollback (presets Decommission / Full), manifest-driven	Uninstall-SoaToolkit.ps1	AD, GPOs, hosts

> Every object the toolkit creates carries the marker **[SoaToolkit] Managed by SOA Toolkit - do not modify manually** and a link to the repository. Uninstall removes only objects created by the toolkit; previous values are restored from the manifest.

4. Topology - no single point of failure

Function	Runs on	Why
Enforcement engine (Microsoft)	every writable DC	ntdsai.dll
Onboarding (event-triggered)	every writable DC	Security events exist only on the DC that processed the write; the agent may write to any writable DC
Reconcile (staggered)	every agent host (DC or member server)	domain-wide LDAP; needs no DC
Monitoring	every toolkit host	DC-local, agent-local and domain-wide checks
Setup / rollback / tests	admin workstation	no permanent footprint

Nothing runs only on the PDC emulator: without rotation every write is idempotent. Microsoft supports the agent on DCs and member servers, recommends Tier-0 hardening of agent hosts, and recommends 3 active agents [R27].

5. Key findings

#	Finding	Evidence
K2	An expired AD password blocks FIDO2 / WHfB Cloud Kerberos Trust sign-in.	Documented [R10]
K3	Spec: PE never set with SCRIL/PNE; MS-SAMR "never must change" for SCRIL. Describes domains without rolling (see K16).	Documented [R14]
K5/K6	Enforced blocks LDAP modify / modify DN / restore for non-allow-listed identities; add/delete allowed. One stale SID → policy fails to load; max 64 SIDs.	Documented [R6]
K7	A direct userAccountControl mapping is not applied; accountDisabled toggles only 0x2, SCRIL is preserved.	Observed
K9	Rolling needs: attribute TRUE, DFL ≥ 2016, SCRIL, no PNE, expired; writes a random secret and sets pwdLastSet.	Documented [R13]
K10	**Passwordless sign-in via Cloud Kerberos Trust + AVD SSO succeeds after expiry; the DC rolls the secret during the sign-in.**	Observed
K11	Setting SCRIL re-randomizes the secret, pwdLastSet unchanged; rewrite / clear do not re-randomize; random reset moves pwdLastSet.	Observed
K16	**With rolling enabled, SCRIL secrets expire on schedule** (computed expiry = date, PE set at expiry).	Observed
K17	"Password never expires" → expiry "never" → no rolling.	Observed

#	Finding	Evidence
K18	Deny-change ACEs do not change the randomization.	Observed
K19	Synced groups are universal; PSOs apply only to users / global groups → AD-native global group.	Documented [R9, R29]
K21	4720 / 5136 are logged only on the DC that processed the write → onboarding on every writable DC.	Documented / Inferred

6. Microsoft documentation vs. toolkit

Topic	Microsoft	Toolkit
Updates, restart, container check, marking	manual steps	**same**; verified per DC (container incl. originating DC)
KIR feature enablement	deploy the Group Policy package	**same effect, automated**: MSI extracted, ADMX to the central store, one GPO per OS with WMI filter; only the download is manual
Policy CN=Cloud	Set-CloudSyncSOAPolicy.ps1	**deviation**: same object created by the toolkit (Audit); container never created (F2); all agent gMSAs (F6)
Mode switch	"run the script again" (does nothing, F1)	**deviation**: keywords written directly, pre-checks, replication wait; Audit first
Enablement check	Check-CloudSyncSOAPolicy.ps1 (domain-wide only, F3; fixed gMSA DN, F4)	**deviation**: per DC ntdsai / KIR / RSoP / event 3095
Diagnostics	"Security Diagnostics = 1"	value "2 Security Events" via GPO (F5)
Passwordless target state, onboarding, reconcile, monitoring, tests, rollback	–	**additional**

7. Rollback and decommissioning

- Steps (in order): SetModeAudit, StopTasks, RevertUsers (optional, with warning), RemovePso, RemoveAllowList (before RemoveGmsa!), RemovePolicy, RemoveTasks, RemoveAudit, RemoveDelegation, RemoveBatchLogonGpo, RemoveKirGpo, RemoveDiagnosticsGpo, RemoveGmsa, RemoveGroups, RestoreRolling, RemoveAccounts, Verify.
- **Decommission** preset: the toolkit is removed, while the target state, PSO, policy and KIR GPO stay. **Existing users keep working** (SCRIL + DC rolling + PSO are native). New users and SOA conversions are no longer configured.
- **Full** preset: original state as far as possible; users keep SCRIL unless RevertUsers is run explicitly (without SCRIL, rolling stops and the 0x17 problem returns).

8. References (selection)

ID	Source	Retrieved
R6	Configure AD user and group enforcement in Microsoft Entra Cloud Sync (preview), ms.date 2026-08-11	2026-10-20
R7/R8	Set-CloudSyncSOAPolicy.ps1 (commit 3f03ef2d) / Check-CloudSyncSOAPolicy.ps1 (commit 0afc4332), github.com/AzureAD/EntraIDGovernance	2026-10-16
R10	Passwordless security key sign-in to on-premises resources	2026-10-15
R13	[MS-SAMS] 3.3.5.7.2 (automatic rolling)	2026-10-19
R14	[MS-ADTS] msDS-User-Account-Control-Computed	2026-10-15
R19	DISA STIG V-243476 (rotation of SCRIL secrets ≤ 60 days)	2026-10-15
R27	Microsoft Entra Cloud Sync prerequisites (agent on DC supported, Tier 0, 3 agents)	2026-10-20
R28	Use Group Policy to deploy a Known Issue Rollback	2026-10-20
R29	AD DS fine-grained password policy step-by-step	2026-10-20

Repository: https://github.com/mayer-bautechnik/cloudsync-soa-toolkit - full list with URLs in README.md. Copyright (c) 2026 GEBR. MAYER GmbH + Co. KG and Johannes Lämmermann. Licensed under the Mozilla Public License 2.0.